

Fintech / NBFC DPDPA Starter Checklist

Your fintech or NBFC doesn't just process transactions — it verifies, profiles and shares financial data every day. Work through these ten areas to bring KYC, consent, profiling, partner/agent access and retention under DPDPA-ready control. This is a DPDPA-readiness checklist and sits alongside your RBI obligations, not instead of them.

KYC

PAN / Aadhaar

Bank Data

Credit Bureau

Consent Evidence

Profiling

DSAs & Agents

Retention

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with consent evidence, KYC handling and agent access — they remove the most risk for the least effort.

1 KYC & financial-data inventory

- ☐ List where customer financial data is collected — app, website, KYC flow, DSAs, call centre, partners.
- ☐ Record what each dataset holds (PAN, Aadhaar, bank, bureau, UPI, repayment), why, and who can access it.
- ☐ Collect only the data the product actually needs.
- ☐ Keep one core system of record so you always know what you hold.
- ☐ Tell customers, in clear notice, how their financial data is used and shared.

2 PAN / Aadhaar / bank data handling

- ☐ Use your regulated KYC/eKYC/CKYC flow — not WhatsApp, email or staff phones.
- ☐ Mask or tokenise identifiers where the full value isn't needed.
- ☐ Restrict who can view and export PAN, Aadhaar and bank statements.
- ☐ Don't keep duplicate copies on agent or staff devices.
- ☐ Set a deletion rule for KYC and bank data once the purpose ends.

3 Bureau check & credit-score data

- ☐ Capture clear, traceable consent before pulling bureau data.
- ☐ Limit who can pull, view and store credit reports and scores.
- ☐ Don't reuse bureau/repayment data for unrelated marketing without consent.
- ☐ Log bureau pulls so you can show purpose and access.
- ☐ Apply a retention rule to bureau reports and score history.

4 Consent & notice evidence

- ☐ Capture timestamped consent for collection, verification, profiling and partner sharing.
- ☐ Avoid bundling consent into terms and conditions without clear explanation.
- ☐ Make notice specific — what data, what purpose, which partners, how long.
- ☐ Keep consent evidence traceable and easy to retrieve.
- ☐ Operationalise withdrawal, correction and deletion across systems and partners.

5 Profiling & underwriting governance

- ☐ Document scoring, eligibility and risk-model purpose and data inputs.
- ☐ Identify decision points, model owners and review steps.
- ☐ Keep human review where decisions materially affect customers.
- ☐ Make the customer notice for automated decisions clear.
- ☐ Review model inputs for unnecessary or high-impact data.

6 DSA / field-agent / collection-agent controls

- ☐ Give agents role-based, monitored access — only what each role needs.
- ☐ Prohibit exporting customer lists to Excel/CSV/WhatsApp.
- ☐ Stop customer follow-up on personal phones and personal WhatsApp.
- ☐ Bind agents and DSAs with data-protection terms.
- ☐ Remove ex-agent access the same day they leave.

7 Payment, UPI & settlement partners

- ☐ Keep a register of payment, UPI, wallet and settlement partners.
- ☐ Share only the data each partner needs for the transaction.
- ☐ Confirm what each partner stores and for how long.
- ☐ Review partner access and data flows periodically.
- ☐ Bind partners with data-processing/sharing terms.

8 Vendor & dashboard access

- ☐ Map vendors with access — KYC, account aggregator, fraud/risk, cloud, CRM, analytics.
- ☐ Give least-privilege access to vendor dashboards.
- ☐ Turn on MFA on core systems, dashboards and admin accounts.
- ☐ Review vendor and dashboard access at least twice a year.
- ☐ Remove old vendor access promptly when contracts end.

9 Rejected application & KYC retention

- ☐ Set a retention period for rejected applications, KYC, bank and bureau data.
- ☐ Don't keep customer financial records indefinitely for 'future offers'.
- ☐ Schedule a periodic review to archive or delete records past their period.
- ☐ Offer customers correction and deletion of their data.
- ☐ Write retention rules down so the whole team applies them consistently.

10 Financial-data breach response

- ☐ Write a one-page plan: who to call and what to do first if data is exposed or a list is leaked.
- ☐ Know how to quickly lock a compromised dashboard, account or agent access.
- ☐ Keep a contact list (security, IT, compliance, and a way to reach affected customers).
- ☐ Be ready to notify the Data Protection Board and affected customers as required.
- ☐ After any incident, record what happened and what you changed.